

Documentation-Driven Threat Analysis

Thesis Chapters 2–4

Closure and reopen record

Freeze del background, research gap e documentation metamodel prima della Base Analysis

Baseline precedente alla finalizzazione. `ec6c0107e0d5c0460d2afcbe12dae6f40bc5e6c5`.

Significato di FINAL. Stabile per lo scope corrente della tesi, non immutabile. Una riapertura richiede un criterio esplicito e un controesempio materiale.

Indice

1	Scopo del record	2
2	Capitolo 2 – Background	2
3	Capitolo 3 – Stato dell’arte e research gap	2
4	Capitolo 4 – Documentation metamodel and authoring rules	2
4.1	Risultati consolidati	3
4.2	Elementi ancora aperti ma non appartenenti alla closure del Capitolo 4	3
5	Freeze rule	4
6	Prossimo confine di ricerca	4

1 Scopo del record

Questo record stabilisce un freeze di ricerca per il blocco della tesi che motiva e definisce il layer documentale governato prima di iniziare la Base Analysis. La chiusura impedisce che i capitoli già stabilizzati vengano continuamente riscritti per accomodare dettagli appartenenti ai layer analitici o di tooling.

2 Capitolo 2 – Background

CLOSED / FINAL

Il Capitolo 2 è semanticamente chiuso. Non richiede una nuova elaborazione concettuale prima della Base Analysis.

Conserva le distinzioni secondo cui threat analysis può iniziare prima dell'implementazione, documentazione e modello analizzabile non sono sinonimi, metodologie diverse possono richiedere viewpoint diversi, Finding/minaccia/mitigazione/SecurityRequirement sono artefatti distinti, output automatici o LLM restano candidati fino a review, e traceability/provenance/change-awareness influenzano la validità analitica.

Reopen clause – Capitolo 2

Riaprire solo per errore fattuale/bibliografico materiale, claim materialmente non supportato o falsificazione di una distinzione fondativa usata dalla tesi. Un nuovo BAE o una nuova relazione non costituiscono da soli un trigger.

3 Capitolo 3 – Stato dell'arte e research gap

CLOSED / FINAL dopo correzione editoriale di coerenza

G1–G4 e lo scope della tesi restano invariati. La finalizzazione corregge soltanto un forward reference ormai stale.

Il research gap resta composto da: documentazione portable-by-construction verso rappresentazione analizzabile revisionata; common core methodology-neutral; risultati method-specific verso finding revisionati e requisiti di sicurezza governati; change-aware traceability e re-analysis.

Reopen clause – Capitolo 3

Riaprire solo se il research gap o lo scope valutato vengono materialmente falsificati/modificati, oppure se prior work viene trovato a risolvere una discontinuità dichiarata nello stesso senso end-to-end valutato dalla tesi.

4 Capitolo 4 – Documentation metamodel and authoring rules

CLOSED / FINAL dopo consolidamento S1.5 + S2

Il Capitolo 4 incorpora definitivamente il documentation metamodel fino a SecurityRequirement.

Gerarchia di tipo:

```
GovernedDocument
|
+-- MacroRequirement
+-- Decision
'-- Requirement [abstract]
    normativeClause : NormativeClause [1..*]
    |
    +-- FunctionalRequirement
    '-- SpecializedRequirement [abstract]
        '-- SecurityRequirement
```

Percorso concreto di authoring/ownership:

```
Project problem framing [method precondition]
-> MacroRequirement
-> Decision
-> FunctionalRequirement
-> SecurityRequirement
    (concrete SpecializedRequirement)
```

4.1 Risultati consolidati

- MR e single macro responsibility;
- Decision come significant commitment sotto un solo MR;
- FR come Requirement operativo indipendentemente assessabile sotto una sola Decision;
- Requirement [abstract] come obbligazione normativa governata comune;
- Requirement.normativeClause : NormativeClause [1..*];
- coherent-unit e split-on-independence;
- NormativeObligation come metaclass L1 separata REJECTED;
- SpecializedRequirement come strengthening normativo di esattamente un FR;
- composizione congiuntiva, removal test, realization separation e boundary con functional correctness;
- SecurityRequirement IS-A SpecializedRequirement;
- protectedSecurityProperty : SecurityProperty [1];
- failure-mode explicitness nelle normative clauses;
- cause neutrality e single governing security property;
- Attack/Finding/Risk/Control/evidence esclusi dalla semantica core del SecurityRequirement.

4.2 Elementi ancora aperti ma non appartenenti alla closure del Capitolo 4

Lifecycle/history/change-event completo; esatta rappresentazione L2 di NormativeClause; tassonomia SecurityProperty; possibile identità strutturale futura di SecurityFailureMode; Base Analysis/BAE; AnalysisRecord/Finding; STRIDE/STRIDE-AI; Risk/Control/evidence; provenance analitica strutturale.

Reopen clause – Capitolo 4

Riaprire solo se una fase successiva produce un failure semantico concreto e ricorrente non rappresentabile senza cambiare il contratto documentale governato. Il controesempio deve identificare il minimo owning layer e attivare regressione dei corpus accettati.

Non riaprono da soli il capitolo: un nuovo tipo/relazione BAE, una proiezione grafica, un campo privato di plugin, un sinonimo suggerito dal tool, un candidato LLM, una nuova tecnica di implementazione/control.

5 Freeze rule

Dopo il commit di finalizzazione:

```
Chapter 2  CLOSED / FINAL
Chapter 3  CLOSED / FINAL
Chapter 4  CLOSED / FINAL
```

Il lavoro successivo deve referenziare questi capitoli invece di retrofittarli continuamente. Correzioni editoriali restano possibili; la riapertura semantica richiede i criteri sopra.

6 Prossimo confine di ricerca

Il prossimo blocco autorizzato è Base Analysis. Il primo microstep è definire responsabilità e confine della rappresentazione analizzabile methodology-neutral prima di fissare una tassonomia BAE o applicare un threat method.